

Contents

1	権限設計書 (運営者)	1
1.1	1. 文書概要	1
1.1.1	1.1 目的	1
1.1.2	1.2 対象範囲	1
1.1.3	1.3 版数	1
1.1.4	1.4 関連ドキュメント	1
1.2	2. ロール一覧	2
1.2.1	2.1 単一ロール採用理由	2
1.2.2	2.2 ロール識別子	2
1.3	3. 画面別権限	2
1.4	4. 機能別権限	3
1.5	5. API 別権限	3
1.6	6. 緊急時のみ可操作	4
1.7	7. 4-eyes 対象 10 操作 (本書の中核、付録 E から移管)	4
1.7.1	7.1 ハードゲート 3 操作 (KV フラグが false なら API 拒否)	4
1.7.2	7.2 承認ログ 7 操作	4
1.7.3	7.3 ハードゲート KV フラグの管理	5
1.7.4	7.4 自己承認禁止 / 自己却下禁止 / 取下げ規約	5
1.8	8. 4-eyes 未承認・権限不足時の動作	5
1.9	9. 運営者アカウント・ライフサイクル	5
1.10	10. 未決事項	6
1.11	11. 変更履歴	6

1 権限設計書 (運営者)

1.1 1. 文書概要

1.1.1 1.1 目的

運営者システムの権限モデルを一元化する。単一ロール **service_operator** + **4-eyes 対象 10 操作** (ハードゲート 3 + 承認ログ 7) を中心に、画面別・API 別の操作可否を定義する。

1.1.2 1.2 対象範囲

- 対象: 運営者ロール (**service_operator**)、4-eyes 対象 10 操作、画面別・API 別権限
- 対象外: 認可判定フロー ([09_ 認証認可設計書.md](#) が正本)、利用者ロール ([01_ メインシステム/個別設計書群/05_ 権限設計書.md](#) 参照)

1.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

1.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
認証・認可設計書	6 段認可判定 / 4-eyes 承認フロー (正本)	09_ 認証認可設計書.md
画面設計書	画面別表示制御 / 4-eyes UI	02_ 画面設計書.md
API 設計書	API 別権限 / X-Approval-Id ヘッダ	03_API 設計書.md
エラー設計書	権限不足 / 4-eyes 未承認時のエラー	06_ エラー設計書.md
テーブル定義書	operator_approvals 物理スキーマ	04_ テーブル定義書.md
メイン側 権限設計書	利用者ロール / 契約上書き	../01_ メインシステム/個別設計書群/05_ 権限設計書.md

1.2 2. ロール一覧

(§3.1から移管)

ロール ID	ロール名	概要	利用者	範囲
service_operator	運営者	単一ロール、open-faq 運営事業者のメンバー	運営事業者	全契約横断(各種ガード適用)

1.2.1 2.1 単一ロール採用理由

MVP は単一 **service_operator** ロールで運用。運営者は SCR-090～099 の運用機能を扱い、操作ごとの安全性は以下で担保:

1. IP allowlist(認証・認可設計書 09 §3)
2. MFA(09 §4)
3. 再認証(5分以内、09 §5)
4. 4-eyes 承認(10 操作のみ、本書 §7)
5. 監査ログ全件(セキュリティ設計書 10 §7)

1.2.2 2.2 ロール識別子

項目	内容
ロール識別子	accounts.user_type='service_operator'
適用数	本 SaaS 提供者の自然人 1 名につき 1 アカウント (FR-220)
認証要件	MFA(TOTP) 必須、未設定時は全画面ログイン不可
パスワード	Argon2id 採用、運営者強化プロファイル (FR-221)
セッション	初期値 8 時間 (D-18)
自己リセット	禁止。MFA / パスワード再設定は別運営者 + 組織内承認
発行・無効化	既存運営者またはブートストラップ管理者のみ

1.3 3. 画面別権限

画面 ID	画面名	全運営者	4-eyes 申請者	4-eyes 承認者	備考
SCR-AUTH / SCR-AUTH-M1	ログイン / MFA	○	-	-	認証フロー
SCR-HOME	ホーム	○	-	-	KPI + 緊急アラート
SCR-090	削除データ参照	○(再認証必須)	-	-	参照のみ
SCR-091	削除データ復元	-	○(申請)	○(承認)	4-eyes 承認ログ
SCR-092	AI パラメータ設定 (本番)	-	○(申請)	○(承認)	4-eyes ハードゲート
SCR-093	契約別レポート / 予算上書き	-	○(申請)	○(承認)	4-eyes 承認ログ
SCR-094	お知らせ作成・配信	○	-	-	即時配信のみ承認ログ
SCR-096	監査ダッシュボード	○(参照のみ)	-	-	エクスポートは再認証
SCR-097	Webhook リプレイ / DLQ	-	○(申請)	○(承認)	4-eyes 承認ログ
SCR-098	PII 誤検出報告	○	○(ルール更新時)	○(ルール更新時)	ルール更新は承認ログ
SCR-099	Webhook 差分検出	○	-	-	手動再処理は再認証
SCR-APPROVALS / M1 / M2	4-eyes 承認画面	○(申請者 / 承認者として)	○	○	4-eyes 中核画面

1.4 4. 機能別権限

機能 ID	機能名	必要権限	4-eyes 種別	関連 SCR
F-OP-AUTH-*	認証 / MFA / セッション	service_operator	-	SCR-AUTH / AUTH-M1
F-OP-DELETE-001	削除データ参照	service_operator + 再認証	-	SCR-090
F-OP-DELETE-002	削除データ復元	service_operator + 再認証 + 4-eyes 承認ログ	承認ログ	SCR-091
F-OP-AI-001	AI パラメータ設定	service_operator + 再認証 + 4-eyes ハードゲート	ハードゲート	SCR-092
F-OP-OVERRIDE-001	契約別上書き	service_operator + 再認証 + 4-eyes 承認ログ	承認ログ	SCR-093
F-OP-NOTIF-001	お知らせ作成・配信	service_operator + 再認証	即時配信のみ承認ログ	SCR-094
F-OP-AUDIT-001	監査ログ閲覧 / エクスポート	service_operator(参照は不要、エクスポートは再認証)	-	SCR-096
F-OP-WEBHOOK-001	Webhook リプレイ	service_operator + 再認証 + 4-eyes 承認ログ	承認ログ	SCR-097
F-OP-PII-001	PII 報告管理 / ルール更新	service_operator + 再認証(更新時)+ 4-eyes 承認ログ(ルール更新時)	承認ログ(ルール更新)	SCR-098
F-OP-WEBHOOK-002	ペイロード差分検出	service_operator(手動再処理は再認証)	-	SCR-099
F-OP-4EYES-*	4-eyes 承認(申請 / 承認 / 却下 / 取下げ)	service_operator(自己承認禁止)	-	SCR-APPROVALS / M1 / M2

1.5 5. API 別権限

03_API 設計書.md を正本とする。主要 API:

API	メソッド	必要権限	4-eyes 種別	関連エラー ID
POST /admin/v1/auth/login	POST	(IP allowlist のみ)	-	E-OP-AUTH-*
POST /admin/v1/auth/mfa/verify	POST	セッション	-	E-OP-MFA-*
POST /admin/v1/me/reauth	POST	セッション + MFA	-	-
POST /admin/v1/approvals	POST	service_operator	申請フロー	E-OP-4EYES-*
POST /admin/v1/approvals/{id}/approve	POST	別運営者(自己承認禁止)	承認ハードゲート	E-OP-4EYES-SELF
POST /admin/v1/approvals/{id}/reject	POST	別運営者 + 再認証	-	E-OP-4EYES-SELF
POST /admin/v1/approvals/{id}/withdraw	POST	申請者本人のみ	-	-
GET /admin/v1/deleted-resources	GET	service_operator	-	-
POST /admin/v1/restorations	POST	service_operator + 再認証	承認ログ	E-OP-RESTORE-LOCKED
PUT /admin/v1/ai-parameters/{scope}/{id}	PUT	service_operator + 再認証 + X-Approval-Id	ハードゲート	E-OP-4EYES-HARDGATE
PUT /admin/v1/overrides/rate-limit/{owner_id}	PUT	service_operator + 再認証 + X-Approval-Id	承認ログ	-
PUT /admin/v1/overrides/budget/{owner_id}	PUT	service_operator + 再認証 + X-Approval-Id	承認ログ	-

API	メソッド	必要権限	4-eyes 種別	関連エラー ID
POST /admin/v1/announcements	POST	service_operator + 再認証	-	-
POST /admin/v1/announcements/{id}/schedule	POST	service_operator + 再認証	-	-
POST /admin/v1/announcements/{id}/send(即時)	POST	service_operator + 再認証 + X-Approval-Id	承認ログ	-
GET /admin/v1/audit-logs	GET	service_operator	-	-
POST /admin/v1/audit-logs/exports	POST	service_operator + 再認証	-	-
POST /admin/v1/webhooks/replay	POST	service_operator + 再認証 + X-Approval-Id	承認ログ	E-OP-WEBHOOK-REPLAY-EXPIRED
POST /admin/v1/pii-rules/revisions	POST	service_operator + 再認証 + X-Approval-Id	承認ログ	-

1.6 6. 緊急時のみ可操作

運営者は通常時に全契約横断アクセス可能だが、利用者側 Δ 緊急時のみ可 操作についてはメイン側 [権限設計書 §9](#) を参照。

1.7 7. 4-eyes 対象 10 操作 (本書の中核、付録 E から移管)

詳細フロー・承認モデルは [09_認証認可設計書.md §8](#) を正本とする。本書では一覧と画面・API・retention の対応を保持する。

1.7.1 7.1 ハードゲート 3 操作 (KV フラグが false なら API 拒否)

#	操作	action code	対象 SCR	API	retention_class	ticket_id 必須
1	契約物理削除	owner.physical_delete	SCR-091 派生	DELETE /admin/v1/owners/{id}/physical	7y(billing)	○
2	AI パラメータ変更 (本番)	ai_parameter.update	SCR-092	PUT /admin/v1/ai-parameters/{scope}/{id}	5y(operator_high_priv)	○
3	マスター ローテーション	master_key.rotate	(運用 CLI)	(CLI)	5y	○

1.7.2 7.2 承認ログ 7 操作

#	操作	action code	対象 SCR	API	retention_class	ticket_id 必須
4	契約無効化 (active → suspended)	owner.suspend	SCR-091 派生	POST /admin/v1/owners/{id}/suspend (IF #1 経由)	5y	○
5	契約復元 (削除猶予中 → active)	owner.restore	SCR-091 派生	POST /admin/v1/owners/{id}/restore	5y	○
6	従量単価表・無料枠改定	pricing.update	(運用 CLI)	(CLI)	5y	○
7	契約別レート制限・予算上限の上書き	rate_limit.override / budget.override	SCR-093	PUT /admin/v1/overrides/*	5y	○
8	緊急ウィジェット強制停止	widget.force_stop	SCR-093 派生	POST /admin/v1/widgets/{id}/force-stop	5y	○
9	削除データ復元 (FR-204)	owner.restore_data	SCR-091	POST /admin/v1/restorations	5y	○
10	ハードゲート KV フラグ切替	feature.hard_gate.toggle	(運用 CLI)	(CLI)	5y	○

1.7.3 7.3 ハードゲート KV フラグの管理

KV キー: `feature:hard-gate:<action_code>`

- 対象 action コードは **実装定数 (コード内 const)** で管理
- 許可操作: **緊急一時無効化のみ** (true → false 一時切替)
- 発動条件: セキュリティインシデント + メイン要件 § 6.2.2 の条件成立時
- フラグ変更操作は 4-eyes 承認ログ対象 (`feature.hard_gate.toggle`, `retention_class='5y'`)
- 誤操作で MVP 重大操作 (`owner.physical_delete`) が単独実行可能になるリスクを排除

1.7.4 7.4 自己承認禁止 / 自己却下禁止 / 取下げ規約

ルール	内容
自己承認禁止	DB CHECK: <code>requested_by != approved_by</code> + アプリ層チェック
自己却下禁止	DB CHECK: <code>requested_by != rejected_by</code> + アプリ層チェック
取下げ規約	申請者本人 (<code>requested_by</code>) のみ可。別運営者の取下げは不可

詳細は [09_認証認可設計書.md § 8](#) を正本とする。

1.8 8. 4-eyes 未承認・権限不足時の動作

ケース	システム動作	画面表示	メッセージ ID	関連エラー ID
4-eyes 未承認で操作実行	403 + 専用コード	「承認が必要な操作です。SCR-APPROVALS から申請してください」	MSG-OP-4EYES-NOT-APPROVED	E-OP-4EYES-REQUIRED
4-eyes ハードゲート KV false	403 + 即時拒否	「現在この操作は無効化されています (運営側で有効化が必要)」	MSG-OP-4EYES-HARDGATE-OFF	E-OP-4EYES-HARDGATE
自己承認試行	422 + 専用コード	「自分が申請した操作は承認できません」	MSG-OP-4EYES-SELF	E-OP-4EYES-SELF
自己却下試行	422 + 専用コード	「自分が申請した操作は却下できません」	MSG-OP-4EYES-SELF-REJECT	E-OP-4EYES-SELF
承認 TTL 切れ (72h)	410 + 専用コード	「承認の有効期限が切れました。再申請してください」	MSG-OP-4EYES-EXPIRED	E-OP-4EYES-EXPIRED
再認証期限切れ (5分以内)	403 + 再認証画面誘導	「再認証が必要です」	MSG-OP-REAUTH-REQUIRED	E-OP-REAUTH-REQUIRED
IP allowlist 拒否	401(即時)	(拒否画面なし、HTTP のみ)	-	E-OP-IP-DENIED
payload_hash 改ざん検知	409 + 専用コード	「申請内容が変更されている可能性があります。最新の内容を確認してから承認してください」	MSG-OP-4EYES-PAYLOAD-CHANGED	E-OP-4EYES-PAYLOAD-CHANGED
ticket_id 必須項目欠落	400 + 入力欄エラー	「操作チケット ID を入力してください」	MSG-OP-4EYES-TICKET-REQUIRED	E-OP-INPUT-TICKET-REQUIRED

1.9 9. 運営者アカウント・ライフサイクル

イベント	実行可能者	監査記録
発行 (account.invite)	既存運営者 (MVP は全員) / ブートストラップ管理者	audit_logs(retention_class='5y'), action=operator.invite
MFA 初回設定	本人 (初回 72h セットアップトークン経由)	action=operator.mfa.setup
MFA リセット	別運営者 + 組織内承認	action=operator.mfa.reset

イベント	実行可能者	監査記録
パスワード再設定	別運営者 + 組織内承認	action=operator.password.reset
無効化 (account.disable)	既存運営者	action=operator.disable
再有効化 (account.enable)	既存運営者	action=operator.enable

1.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

1.11 11. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude